

Which agent bricked prod?

A two-question test for enterprise agent identity

THE TEST

Every hop must answer two questions.

Whose authority is being exercised. Which agent exercised it. Keep both and you have something you can authorize and audit. Lose either — most have — and your role model is a slide, not a control.

User disappears behind an app-only token.

A client-credentials hop in the middle of a user-initiated chain. The downstream API sees a service principal with broader rights than the human ever held. Audit table says "App did it." Person is gone.

Agent disappears behind a shared platform identity.

Forty agents built by forty makers all show up at the resource as one client id. The audit table cannot distinguish agent A from agent B without correlating on platform-internal run IDs that were never propagated.

ACL disappears at the ingestion boundary.

Source-system permissions are a property of the system you copied data out of. They are not in the chunk. RAG retrieves flat. Bob can read through the bot things he could never open at source — and your compliance plane cannot enumerate the corpus.

WHERE THIS MATTERS MOST

A misrouted write to a
Jira ticket is an email. A
misrouted write to a
setpoint moves actuators.

The AI-first roadmap reaches the shop floor on purpose — that is where the margin is made. The chain that issues the write was already missing the actor. Now it points at the part of the company that physically moves.

WHY THIS HASN'T BLOWN UP YET

Living off the chatbot.

The only thing saving us is compartmentalisation — the agents do not talk to each other yet. The day they do, lateral movement is the published API and privilege escalation is whichever neighbour has the broader connector. No payload, no CVE — polite REST calls.

WHAT IT LOOKS LIKE ON A BAD TUESDAY

An agent closes a change-freeze hold.

Alice asks the bot to tidy stale tickets. The maker's admin PAT bulk-closes across projects Alice can't see — including the hold on a forward-only migration. Pipeline cuts the build. Migration locks the orders table. Three and a half hours of downtime. Forensics from authoritative logs: impossible.

If your logs cannot prove who and which, you don't have agent auth.

You have a shared account with an LLM bolted onto it. Full essay, interactive diagrams, and audio cuts (DE + EN) — link in the comments.